# DOCUMENT CONTROL PAGE

| Field | Details |
|---|---|
| Document Title | Vulnerability Management & Secure Testing Policy |
| Document ID | CIL-GRC-VMSTP-2026-001 |
| Version | 1.0 |
| Effective Date | 18 February 2026 |
| Review Date | 18 February 2027 |
| Policy Domain | ISO/IEC 27002:2022 –Domain 8 (Technological Controls) |
| Control Reference/Sub-Domain | 8.8, 8.9, 8.32 |
| Policy Owner | Chief Information Security Officer (CISO) |
| Policy Author | Head of Security Engineering |
| Reviewer(s) | Legal & Compliance Officer, Data Protection Officer, Head of Security Operations |
| Classification | Confidential - Internal Use Only |
| Distribution | All Employees, Contractors, Third Parties (where applicable) |
| Supercedes | New Document |

**APPROVED BY**
**Managing Director (CEO)**

_____

For: Cyberinfiniti Ltd

**Vulnerability Management & Secure Testing Policy Summary**

## 1. Overview and Organisational Context

CyberInfiniti Ltd In the course of its operations handles highly sensitive assets, such as client data, threat intelligence, security configurations, cloud-hosted systems, and personal data regulated under Nigeria Data Protection Act 2023. Given this risk exposure, the organisation must maintain a robust vulnerability management and secure testing framework to protect the confidentiality, integrity, and availability of its systems and data. Failure to effectively manage vulnerabilities could lead to regulatory breaches, financial loss, reputational damage, and loss of client trust.

This policy establishes a structured governance framework aligned with ISO/IEC 27002:2022 controls 8.8 (Technical Vulnerability Management), 8.9 (Configuration Management), and 8.32 (Change Management).

## 2. Purpose and Scope

The purpose of this policy is to define a **risk-based approach** to:

- Identifying and assessing vulnerabilities
- Prioritising and remediating risks
- Maintaining secure system configurations
- Conducting secure testing activities
- Integrating remediation into change management processes

The policy ensures protection of information assets, reduction of exploit risks, and compliance with regulatory and contractual obligations.

It applies across the organisation's entire technology landscape, including: Infrastructure (networks, endpoints, SOC systems, cloud environments), Applications (internal systems, client-facing platforms, APIs, DevOps pipelines)&Third-party components (SaaS services, vendors, open-source libraries)

## 3. Governance and Policy Requirements

CyberInfiniti Ltd commits to:

- Identifying vulnerabilities in a timely manner
- Assessing risk exposure using defined criteria
- Remediating vulnerabilities within established service-level timelines
- Maintaining secure configuration baselines
- Conducting periodic and risk-based testing
- Tracking and auditing all vulnerability management activities

This ensures accountability, traceability, and alignment with international standards such as ISO/IEC 27002:2022.

## 4. Vulnerability Management Framework

### 4.1 Identification and Scanning

The organisation adopts a proactive approach to vulnerability identification through:

- Vendor security advisories
- Threat intelligence feeds
- Automated vulnerability scanning
- Open-source dependency analysis
- Configuration compliance checks

Scanning is conducted regularly based on system criticality, with frequencies ranging from **monthly (internal systems, cloud)** to **per release (applications)** and **quarterly (external systems)**.

### 4.2 Risk Classification and Remediation

Vulnerabilities are prioritised based on:

- CVSS scores
- Exploit availability
- Asset criticality
- Data sensitivity
- Business impact

Defined remediation timelines include:

- Critical: within 7 days
- High: within 14 days
- Medium: within 30 days
- Low: risk acceptance or scheduled remediation

### 4.3 Tracking and Reporting

All vulnerabilities are:

- Logged in a central vulnerability register
- Assigned to responsible owners
- Tracked through to resolution
- Verified through re-scanning

Monthly reviews are conducted by the CISO to ensure oversight and accountability.

## 5. Configuration and Secure Testing Controls

### 5.1 Configuration Management

Secure configuration baselines are maintained across systems, including operating systems, network devices, cloud environments, and databases. These baselines are aligned with industry standards such as CIS benchmarks, vendor hardening guides, and security best practices.

Key controls include:

- Prohibition of unauthorized configuration changes
- Quarterly baseline reviews
- Documentation and approval of any deviations

### 5.2 Secure Testing Practices

CyberInfiniti implements multiple layers of security testing:

- **Penetration Testing**: Conducted annually and after major system changes
- **Secure Code Testing**: Includes SAST, DAST, dependency scanning, and secrets detection
- **Advanced Testing**: Red teaming and adversarial simulations for high-risk systems

These practices ensure early detection of weaknesses and validation of security controls.

## 6. Change Management and Exception Handling

All remediation activities must follow formal change management processes aligned with ISO/IEC 27002:2022 control 8.32. This includes:

- Documented change requests
- Pre-deployment testing
- Approval from the Change Advisory Board (CAB)
- Defined rollback procedures

Emergency changes are permitted but must be documented retrospectively.

Where remediation cannot be completed within defined timelines:

- A formal risk assessment must be conducted
- Compensating controls must be implemented
- Risk acceptance must be approved by the CISO and relevant stakeholders
- Exceptions must include review timelines and expiration dates

**7. Compliance, Monitoring, and Reporting**

This policy supports compliance with:

- Nigeria Data Protection Act 2023 (data protection)
- ISO/IEC 27001 certification requirements
- Client contractual service-level agreements
- SOC 2 security principles

Compliance is monitored through:

- Monthly vulnerability dashboards
- Quarterly executive risk reports
- Annual penetration testing reports
- Internal audits

Key performance indicators include:

- SLA compliance rates
- Time to remediate vulnerabilities
- Number of open vulnerabilities
- Recurrence rates

**8. Roles, Responsibilities, and Incident Integration**

Clear accountability is established across roles:

- Executive management provides oversight
- The CISO owns the policy and governance
- Security and DevSecOps teams manage scanning and testing
- IT teams handle patching and infrastructure security
- System owners approve risk acceptance

If a vulnerability is exploited, the **Incident Management Policy** is triggered, followed by root cause analysis and integration of lessons learned into continuous improvement processes.

**9. Training, Review, and Continuous Improvement**

CyberInfiniti ensures ongoing capability development through:

- Secure coding training
- DevSecOps and testing training
- Configuration management awareness programs

The policy is reviewed:

- Annually
- After major incidents
- Following regulatory or audit changes

All personnel must formally acknowledge the policy and their responsibilities.

**Conclusion**

This policy establishes a **comprehensive, risk-driven approach** to vulnerability management and secure testing within CyberInfiniti Ltd. By aligning with ISO/IEC 27002:2022 and regulatory requirements such as Nigeria Data Protection Act 2023, the organisation ensures proactive risk mitigation, operational resilience, and sustained client trust in an evolving cybersecurity landscape.

# 1. ORGANISATIONAL CONTEXT

CyberInfiniti Ltd is a cybersecurity startup providing:

- Managed Security Services (MSSP)
- Penetration Testing & Red Team Services
- SOC Monitoring Services
- Governance, Risk & Compliance Advisory
- Cloud & Infrastructure Security Consulting
- Cybersecurity Training & Academy Portal

As a cybersecurity organization handling:

- Client-sensitive information
- Threat intelligence data
- Security tooling configurations
- Cloud-hosted applications
- Personal data under NDPA 2023

CyberInfiniti must maintain a robust vulnerability management and secure testing framework to protect:

- Confidentiality
- Integrity
- Availability
- Regulatory compliance
- Client trust

---

# 2. PURPOSE

This policy establishes a structured, risk-based approach to:

- Identifying vulnerabilities
- Assessing and prioritizing risks
- Remediating technical weaknesses
- Managing configuration baselines
- Conducting secure testing activities
- Integrating vulnerability remediation into change management

This policy ensures:

- Protection of information assets
- Reduction of exploit risk
- Compliance with regulatory and contractual obligations
- Alignment with ISO/IEC 27002:2022 controls 8.8, 8.9, 8.32

---

# 3. SCOPE

This policy applies to:

### Infrastructure

- Internal corporate networks
- Endpoints and servers

- SOC systems
- Security appliances
- Cloud environments (Azure, AWS)

### Applications

- Client-facing platforms (e.g., Security Academy Portal)
- Internal web applications
- APIs
- DevOps pipelines

### Third-Party Components

- SaaS solutions
- Managed service providers
- Open-source libraries

---

# 4. POLICY STATEMENT

CyberInfiniti Ltd shall:

1. Identify technical vulnerabilities in a timely manner.
2. Evaluate exposure risk.
3. Remediate within defined service-level timelines.
4. Maintain secure configuration baselines.
5. Conduct periodic secure testing.

6. Integrate remediation into formal change management.
7. Track, document, and audit vulnerability treatment.

---

# 5. VULNERABILITY MANAGEMENT REQUIREMENTS

(Aligned with ISO 27002:2022 – 8.8)

## 5.1 Vulnerability Identification

The organization shall:

- Subscribe to vendor security advisories.
- Monitor threat intelligence feeds.
- Conduct automated vulnerability scans.
- Perform dependency scanning for open-source components.
- Review configuration compliance against secure baselines.

---

## 5.2 Vulnerability Scanning Schedule

| Environment | Frequency |
|---|---|
| Internal Systems | Monthly |
| External Perimeter | Quarterly |
| Cloud Infrastructure | Monthly |
| Applications (SAST/DAST) | Per Release |
| Client-Facing Systems | Quarterly or After Major Change |

---

## 5.3 Risk Classification & Remediation SLAs

| Severity | Remediation Timeline |
|---|---|
| Critical | Within 7 Days |
| High | Within 14 Days |
| Medium | Within 30 Days |
| Low | Risk Accepted or Scheduled |

Severity is determined using:

- CVSS Score
- Exploit availability
- Asset criticality
- Data sensitivity
- Business impact

---

## 5.4 Vulnerability Tracking

All identified vulnerabilities shall be:

- Logged in the Vulnerability Register
- Assigned to responsible owners
- Tracked to closure
- Verified through re-scan
- Reviewed monthly by CISO

# 6. CONFIGURATION MANAGEMENT

(Aligned with ISO 27002:2022 – 8.9)

CyberInfiniti shall maintain secure configuration baselines for:

- Operating systems
- Network devices
- Cloud resources
- Containers
- Security tools
- Databases

---

## 6.1 Secure Baseline Standards

Baselines shall be based on:

- CIS Benchmarks
- Vendor hardening guides
- NIST security standards
- Cloud security best practices

---

## 6.2 Configuration Control

- Unauthorized configuration changes are prohibited.

- Baselines reviewed quarterly.
- Deviations documented and approved.

---

# 7. SECURE TESTING REQUIREMENTS

## 7.1 Penetration Testing

- Conducted annually at minimum.
- Conducted after major system upgrades.
- Performed by independent internal team or external provider.
- Report delivered to Executive Management.

---

## 7.2 Secure Code Testing

All applications must undergo:

- Static Application Security Testing (SAST)
- Dynamic Application Security Testing (DAST)
- Dependency scanning
- Secrets detection
- Manual security review (where high risk)

---

## 7.3 Red Team / Advanced Testing

High-risk systems may undergo:

- Red Team exercises
- Cloud security posture testing
- Adversarial simulation

---

# 8. CHANGE MANAGEMENT INTEGRATION

(Aligned with ISO 27002:2022 – 8.32)

All vulnerability remediation actions must:

1. Follow formal Change Management process.
2. Be documented in change ticket system.
3. Undergo testing prior to deployment.
4. Receive approval from Change Advisory Board (CAB).
5. Include rollback plans.

Emergency patches may follow expedited change process but must be documented retroactively.

---

# 9. EXCEPTION MANAGEMENT PROCESS

If remediation cannot occur within SLA:

1. Risk assessment must be documented.
2. Compensating controls identified.

3. Formal risk acceptance required.
4. Approval required from:
    - CISO
    - System Owner
    - Business Executive

Exceptions must include expiration date and periodic review.

---

# 10. REGULATORY & CONTRACTUAL ALIGNMENT

This policy supports compliance with:

### Nigeria Data Protection Act (NDPA 2023)

- Protects personal data from unauthorized access due to vulnerabilities.

### Client Contractual SLAs

- Meets agreed vulnerability remediation timelines.

### ISO/IEC 27001 Readiness

- Supports Annex A controls for certification.

### SOC 2 (Security Principle)

- Demonstrates risk mitigation and control monitoring.

---

# 11. ROLES & RESPONSIBILITIES

| Role | Responsibility |
|---|---|
| MD | Executive approval |
| CISO | Policy ownership & oversight |
| Security Engineering Lead | Vulnerability scanning & remediation |
| SOC Manager | Monitoring & reporting |
| DevSecOps Lead | Secure testing integration |
| IT Infrastructure Manager | Patch deployment |
| System Owners | Risk acceptance decisions |
| All Employees | Report suspected vulnerabilities |

---

# 12. MONITORING & REPORTING

- Monthly vulnerability dashboard
- Quarterly executive risk report
- Annual penetration testing summary
- Internal audit review

KPIs include:

- SLA compliance rate
- Time-to-remediate
- Open vulnerability count
- Recurrence rate

---

# 13. INCIDENT LINKAGE

If a vulnerability is exploited:

- Incident Management Policy is triggered.
- Root cause analysis required.
- Lessons learned integrated into improvement plan.

---

# 14. TRAINING & AWARENESS

- Secure coding training (annual)
- DevSecOps secure testing training
- Configuration management workshops
- Vulnerability awareness sessions

---

# 15. POLICY REVIEW & CONTINUAL IMPROVEMENT

This policy shall be reviewed:

- Annually
- After major incidents
- After regulatory changes

- After audit findings

Management review results shall feed into updates.

---

# 16. POLICY ACKNOWLEDGEMENT

All technical personnel must acknowledge:

- Understanding of responsibilities
- Commitment to comply
- Awareness of remediation timelines

Recorded via HR compliance system.

---

# EXECUTIVE STATEMENT

CyberInfiniti Ltd recognizes that proactive vulnerability management and secure testing are foundational to maintaining trust, regulatory compliance, and operational resilience.

Through structured governance aligned with ISO/IEC 27002:2022 controls 8.8, 8.9, and 8.32, the organization commits to continuous protection against evolving cyber threats.

---